

Lesson 2-3

Incident Response and Risk Management

Learning Objectives

- Explain what a security incident is and describe the stages of incident response in the correct order.
- Apply the idea of risk assessment by prioritizing risks according to their impact and likelihood.

Even a well-protected system can be attacked. When a security incident happens — data leaked, files tampered with, or a service knocked offline — a rushed and unplanned reaction only makes the damage worse. Organizations follow a clear, ordered response so that damage is contained, the cause is removed, and the same problem does not return. They also decide in advance which risks to guard against first, because no team can fix everything at once.

? Guiding question: When a security incident happens, how should an organization respond in order — and how does it decide which risks to address first?

Key Fact:
Incident response follows six ordered stages, and risk assessment prioritizes risks by impact × likelihood — so an organization acts in the right order and on the right risks first.

Key Concepts:

- security incident
- the six stages
- containment / eradication
- risk = impact × likelihood

📌 **Point!**

1. What is a Security Incident

(1) **(Security incident)**…a situation in which actual damage occurs due to an information security problem.

(2) Typical examples of security incidents

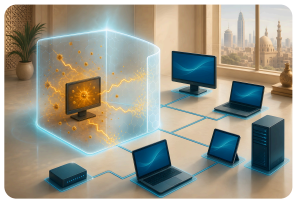
Type	Description
Information leak	Personal information or confidential information is leaked to the outside
Data tampering	Data within a system is altered without authorization
Service outage	A service becomes unavailable due to attacks on the server, etc.

KEY TERMS
security incident — a situation in which actual damage occurs due to an information security problem.

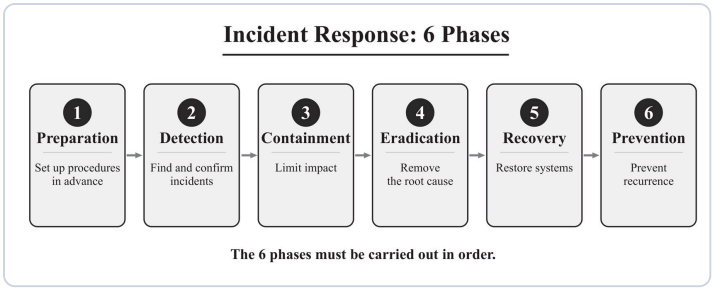
2. The Flow of Incident Response

(1) When a security incident occurs, response proceeds through the following six stages.

Stage	Description
① **Preparation**	Establish response procedures and structures in advance, in preparation for incidents
② **Detection**	Discover and confirm that an incident has occurred
③ **Containment**	Limit the scope of impact so that damage does not spread further
④ **Eradication**	Remove the cause of the incident (e.g., remove malware)
⑤ **Recovery**	Return systems and services to their normal state
⑥ **Prevention of recurrence**	Analyze the cause and take measures so that the same incident does not occur again



Contain first: isolate the infected machine.



Incident Response: 6 Phases

(2) It is important to proceed through the six stages of incident response in order. For example, if recovery is performed without identifying the cause, the same incident may occur again.

3. The Concept of Risk Assessment

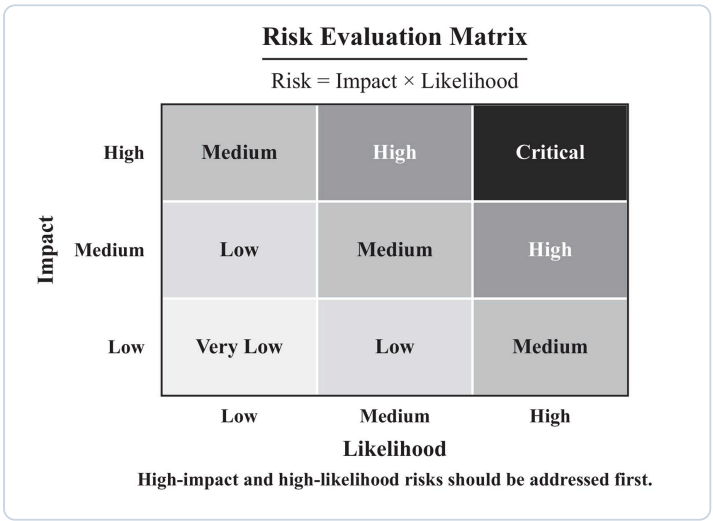
(1) **(Risk)**…the possibility of an information security problem occurring in the future, and its impact.

(2) The size of a risk is determined by the following two factors.

$$\text{Risk size} = \text{Impact} \times \text{Likelihood}$$

① **(Impact)**…how much damage occurs if the risk actually materializes.

② **(Likelihood)**…how high the probability is that the risk will actually materialize.



Risk Evaluation Matrix

(3) Risks with both high impact and high likelihood should be addressed first. Since it is difficult to address all risks at the same time, it is important to set priorities and take measures systematically.

✎ Worked Example

(1) Mark each statement (A–D) with ○ if true or × if false.

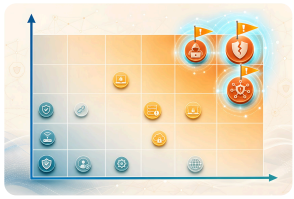
A A security incident is a situation in which actual damage occurs due to an information security problem.



Recover: restore a clean system from backup.

PAUSE & THINK

Why must containment come before eradication in the six-stage response?



Rank risks by impact and likelihood; fix the worst first.

KEY TERMS

impact — how much damage if a risk occurs.

likelihood — how probable the risk is.

B In incident response, it is important to first prevent the spread of damage before removing the cause.

C The size of a risk can be determined by impact alone.

D The final stage of incident response is prevention of recurrence.

(2) For each of a–d, indicate which stage of the six stages of incident response (A–D) it belongs to.

a Establishing response procedures in advance, in preparation for incidents

b Disconnecting a malware-infected computer from the network

c Removing the malware infection

d Analyzing the cause and taking measures so that the same incident does not occur again

[Choices] **A** Preparation **B** Containment **C** Eradication **D** Prevention of recurrence

✓ Solution

(1)

A Correct definition of a security incident. Therefore, ○.

B Containment (preventing the spread of damage) is performed before eradication (removing the cause). Therefore, ○.

C The size of a risk is determined by both impact and likelihood. Therefore, ×.

D The final stage of the six stages is prevention of recurrence. Therefore, ○.

(2)

a: Preparing in advance is preparation. **A**

b: Disconnecting from the network to prevent the spread of damage is containment. **B**

c: Removing malware is eradication. **C**

d: Cause analysis and countermeasures are prevention of recurrence. **D**

EXAM-STYLE QUESTION

Explain why the six stages of incident response must be carried out in order, using recovery and eradication as an example. **[6] Refer to:** what happens if the cause is not removed.

Try

1 Answer the following questions.

1. What is the term for a situation in which actual damage occurs due to an information security problem?
2. Name the six stages of incident response in order.
3. What are the two factors used to determine the size of a risk?

2 Answer the following questions.

(1) From the following options (A–D), choose the one that is NOT an appropriate example of a security incident.

A Data was encrypted by a ransomware infection.

B Customer information was leaked to the outside through unauthorized access.

C A software update was performed to add new features.

D A web service became unavailable due to an attack on the server.

(2) From the following options (A–D), choose the one that most appropriately describes the concept of risk assessment.

A It is enough to address only risks with large impact.

B It is enough to address only risks with high likelihood.

C Risks with both high impact and high likelihood should be addressed first.

D All risks must be addressed simultaneously.

⚙ Think as an Engineer — Investigate & Decide

A school's student-records system is hit by ransomware: files are encrypted and staff cannot log in. You lead the response.

☐ **Restore from backup immediately**

☐ **Follow the six-stage response in order**

1 · Respond from here. This incident has just been **detected** — files are encrypted and staff are locked out. Starting from where the school is **now**, list the stages still to carry out, and say what each one means for this specific incident.

2 · Assess the risks. For two risks the school faces — (i) another ransomware attack, (ii) a brief power cut — estimate impact and likelihood, and say which to address first.

3 · Decide. Recommend the first three actions the school should take, and give one reason why order matters. **In pairs,** compare your orders and agree together on the single most important first step.

Give evidence for your answer.

Stuck? If you recover before you eradicate the cause, the malware is still there — and the same incident can happen again.

🌍 In a New Context

An online shop has just **detected** that customer data has been leaked. Using the six-stage response and risk assessment, name the next two stages it should carry out and why, and identify one risk it should prioritize afterward.

❓ Lesson Question — Answered

The lesson asked how to respond to an incident in order, and how to prioritize risks. A security incident is any situation where real damage occurs. The response follows six stages in a fixed order — preparation, detection, containment, eradication, recovery, and prevention of recurrence — because acting out of order (for example, recovering before removing the cause) lets the same incident return. To decide what to guard against first, an organization assesses each risk by its size = impact × likelihood, and addresses high-impact, high-likelihood risks first, since no team can fix everything at once. Responding in order and prioritizing by risk together keep damage small and prevent repeats.

KEY TERMS

containment — limit the spread of damage.

eradication — remove the cause.

Exercise

1 Cover the Point! section with a red plastic sheet and quiz yourself in your notebook in numerical order.

2 Read the following passage and answer each question.

A situation in which actual damage occurs due to an information security problem is called (a). When (a) occurs, (b), which prevents the spread of damage, is performed first, followed by (c), which removes the cause of the incident. After that, (d), which returns the system to its normal state, is performed, and finally (e), in which the cause is analyzed to prevent recurrence, is performed.

⭐ REFLECT & CHALLENGE

Reflect: Which stage of incident response do you think is hardest to do well under pressure, and why? **Challenge:** Suggest one thing an organization could prepare in advance (stage 1) that would make the other phases faster.

1. Fill in the blanks (a)–(e).

3 Answer the following questions.

(1) Reorder the risks (a–d) from highest priority to lowest priority based on the concept of risk assessment (impact × likelihood).

a Impact: large (3), Likelihood: high (3)

b Impact: small (1), Likelihood: high (3)

c Impact: large (3), Likelihood: medium (2)

d Impact: small (1), Likelihood: low (1)

(2) From the following options (A–D), choose the one that most appropriately describes the order of incident response.

A Detection → Eradication → Containment → Recovery

B Preparation → Detection → Containment → Eradication → Recovery → Prevention of recurrence

C Detection → Recovery → Containment → Prevention of recurrence

D Containment → Detection → Eradication → Preparation

⭐ Key takeaway

Remember:
Follow the six stages in order (prepare → detect → contain → eradicate → recover → prevent), and prioritize risks by impact × likelihood.